EWB Cybersecurity : Assessment 01

Security Foundations

Submitted by: Ankita Ajay Borade

Batch / Group: Batch - 1

Course: Ewb AI POWERED CYBERSECURITY INTERNSHIP

Assessment: Assessment 01 – Security Foundations

Tasks Covered:

- Task A: Secure a Student Account
- Task B: Analyse a Suspicious Message
- Task C: Triage a Sign-in Alert
- Task D: Review an AI Security Answer

Submission Date: 10 - 11 - 26

Declaration

I confirm that the answers in this assessment are prepared for educational purposes. I have used AI assistance where applicable and reviewed the content before including it in this submission.

Task A: Secure a Student Account

A1. Identify Five Security Risks

Mira's account and laptop have several security risks. These risks can affect the confidentiality, integrity and availability of her information.

Risk	Asset at Risk	CIA Impact	Explanation
1. Using the same short password	Email and learning portal accounts	Confidentiality	If someone discovers her password, they may access both accounts and view her private information.
2. Approving unexpected sign-in prompts	Learning portal account	Confidentiality and Integrity	An unauthorised person may gain access to her account and view or change her information.
3. Postponing device updates	Laptop and stored data	Integrity and Availability	Outdated software may contain security weaknesses that attackers could exploit, causing damage or disruption.
4. Keeping only one project copy	College project files	Availability	If the laptop is lost, damaged or stops working, Mira may lose her project completely.
5. Allowing her friend to use her signed-in laptop	Personal files and college accounts	Confidentiality and Integrity	Her friend may accidentally or intentionally view, delete or change her personal and academic information.

A2. Security Controls and Their Limitations

Risk	Control	How It Helps	Limitation
Weak and reused password	Use a strong and unique password for each account.	It makes accounts harder to access without permission.	Strong passwords can be difficult to remember.
Unexpected sign-in prompts	Never approve unknown login requests. Deny and report them.	It prevents unauthorised sign-in attempts from being approved.	It may not stop every type of attack.
Delayed updates	Enable automatic software and security updates.	Updates fix known security weaknesses and improve protection.	Updates cannot protect against every new threat.
Only one project copy	Keep backup copies on cloud storage or an external drive.	It allows her to recover project files if the laptop is damaged or lost.	Backups must be updated regularly.

Sharing a signed-in laptop	Create a separate user account for her friend and lock her own account.	It keeps her personal files and accounts separate.	It does not completely prevent someone from accessing information if accounts are poorly protected.

Priority of First Three Actions

Mira should take the following actions first:

- **Secure her passwords:** She should immediately change her reused password and create strong, unique passwords for both accounts. This is important because one exposed password could affect multiple account.
- **Stop approving unexpected sign-in requests:** She should deny unknown requests and report them to the college IT team. This helps prevent unauthorised people from entering her account.
- **Install pending security updates:** She should update her laptop regularly to fix known security weaknesses and protect her device.

After these actions, she should create backup copies of her project and set up a separate user account for her friend.

A3. Authentication vs Authorisation

Authentication: Authentication is the process of checking the identity of a user. For example, when Mira enters her username, password and OTP to log in to her college learning portal, the system verifies that she is the correct user.

Authorisation: Authorisation decides what an authenticated user is allowed to access or do. For example, after Mira logs in, she may be allowed to view her study materials, download notes and submit assignments, but she may not have permission to change other students' records.

Therefore, authentication checks who the user is, while authorisation decides what the user can do.

Task B: Analyse a Suspicious Message

B1. Identify Five Warning Signs

The given scholarship email contains several warning signs that suggest it could be a phishing attempt. Phishing is when someone sends a fake email or message to trick people into sharing personal information, passwords or other sensitive details.

Warning Sign	Relevant Phrase from Email	Why It Is Suspicious
1. Different sender and reply addresses	awards@campus-awards.example and help@personal-awards.example	The sender and reply addresses are different. This could mean that replies are being redirected to an unrelated address.
2. Creating urgency	"FINAL WARNING - scholarship expires in 20 minutes"	The short deadline creates pressure and may make students act without checking whether the email is genuine.
3. Asking for password and OTP	"enter your college password and OTP"	Genuine college staff should not ask students to share their passwords or OTPs through an email link.
4. Preventing independent verification	"Do not contact the college office"	This discourages students from checking the message with official college staff and increases the chance of being tricked.
5. Asking for identity documents	"Reply with a photo of your identity card"	Identity cards contain personal information that could be misused if shared with an unknown person.

B2. Safe Verification Process

Before trusting the scholarship email, a student should follow these steps:

- Do not click the link or reply to the email.
- Visit the college's official website or scholarship portal by typing its known address directly into the browser.
- Contact the college scholarship department using an official phone number or email address obtained independently from the college website.
- Ask the college whether the scholarship has actually been approved and whether the email was sent by them.
- Report the suspicious message to the college IT team if it cannot be verified.

Why HTTPS does not prove an email is genuine:

HTTPS means that the connection between the browser and the website is encrypted. However, even a fake website can use HTTPS. It does not prove that the website belongs to the college.

Similarly, a familiar sender display name can be copied or changed. Therefore, students should check the actual email address and verify the information through official college sources.

B3. Response Plan If a Student Has Already Entered Their Password and OTP

If a student has already shared their password and OTP, they should take the following actions immediately:

1. **Change the password:** Open the official college portal directly and change the compromised password immediately. If the same password is used elsewhere, change it on those accounts too.
2. **Contact the IT team:** Inform the college IT department about the incident so they can secure the account, check suspicious login activity and revoke unauthorised sessions.
3. **Check account security:** Review recent login activity, recovery details and multi-factor authentication settings. Report any unfamiliar changes.
4. **Report the email:** Forward or report the suspicious email to the college's official IT or security team. Keep the original message as evidence.
5. **Monitor the account:** Check for unusual activity, unfamiliar messages or changes to personal information. Continue monitoring the account for further suspicious activity.

The student should never share their password or OTP with anyone, including people claiming to be from technical support.

B4. One Important Fact That Cannot Be Established

From the email alone, we cannot confirm whether the scholarship has actually been approved or whether the sender is genuinely connected to the college.

To confirm this, we would need additional evidence such as official scholarship records, confirmation from the college scholarship department and the full email headers showing the actual sending details.

Therefore, the message should be treated as suspicious until it is independently verified.

Task C: Triage a Sign-in Alert

C1. Four-Point Timeline

The following timeline shows the login activities of student07 on 18 October 2026. It includes the observed events and their possible meaning.

Time	Observed Events (Evidence)	Interpretation
09:00 –09:01	Password login was successful and MFA was approved from the usual IP address 192.0.2.10.	This appears to be a normal login from the classroom network.
10:14 –10:16	Two password attempts failed, followed by one successful password attempt from 198.51.100.23.	Someone may have been trying to access the student account.

10:17–10:18	One MFA request was denied and the next was approved. The student says they approved the prompt without intending to sign in.	The approval may have allowed an unauthorised login to continue.
10:20	A session was successfully created from 198.51.100.23.	The account was accessed through a new session after the MFA approval.

C2. Likely Explanation and Alternative Explanation

An unauthorised person may have been trying to access student07's account. After two failed password attempts, the correct password was entered at 10:16. The person then sent an MFA request. Although the first request was denied, the student approved the next request at 10:18, possibly allowing the other person to access the account. A session was created at 10:20.

Alternative Explanation:

The login could have been initiated by the student from another network or device. The student may not have recognised the login attempt and approved the MFA prompt by mistake.

Two Additional Checks:

- Check the device, browser and login details associated with the session to see whether they match the student's usual devices.
- Contact the student through an official channel and verify whether they recognise the device, network and login activity at that time.

These checks can help determine what happened. However, the IP address alone cannot identify the person who used the account.

C3. Three Prioritised Response Actions for the IT Team

1. **Secure the account:** Temporarily restrict or disable the suspicious session, revoke active sessions and help the student reset their password. Check and reset MFA settings if needed. This helps prevent further unauthorised access.
2. **Preserve the evidence:** Save the login logs, timestamps, IP addresses, MFA records and session details before they are lost or changed. This helps the IT team investigate the incident properly.
3. **Investigate and monitor:** Check the account for unusual activity, unauthorised changes and access to personal information. Monitor future login attempts and inform the student about the findings.

C4. Incident Summary

On 18 October 2026, student07's account showed suspicious login activity from an IP address different from the usual classroom network. Two password attempts failed before a successful attempt at 10:16. An MFA request was denied and another was approved at 10:18, followed by session creation at 10:20. The student stated that they did not attempt to log in but approved the prompt by mistake. Unauthorised access is suspected but not confirmed. The IT team should secure the account, preserve evidence and investigate the session details.

Task D: Review an AI Security Answer

D1. Identify and Correct Five Unsafe or Unsupported Claims

The given AI-generated answer contains incorrect information and unsafe suggestions. Each statement needs to be checked before accepting it.

Incorrect Claim or Action	Correct Explanation
1. "The email is safe because it uses HTTPS."	HTTPS only encrypts the connection between the browser and website. Even fake websites can use HTTPS, so it does not prove that the website is genuine.
2. "The sign-in logs prove that the person using 198.51.100.23 stole the password."	The logs show that a successful login happened from that IP address, but they do not identify the person or prove how the password was obtained.
3. "MFA prevents every account compromise."	MFA adds another layer of security, but it cannot prevent every attack. For example, approving an unexpected login request can still allow unauthorised access.
4. "Delete the suspicious logs."	Suspicious logs should be preserved because they contain important evidence, such as login times, IP addresses and authentication results. Deleting them can make the investigation difficult.
5. "Send the student's password to support so they can test it."	Passwords should never be shared with anyone, including support staff. The IT team should use safe account recovery and security checks instead.

D2. Better Prompt for an AI Tool

The following prompt can be used to get a safer and more accurate analysis from an AI tool:

"***Analyse only the fictional cybersecurity evidence provided in this assessment. Identify the possible security risks and explain what the evidence shows. Clearly separate observed facts from assumptions and possible explanations. Do not identify or accuse any person based only on an IP address. Do not ask for passwords, OTPs or other private information. Suggest safe and practical security actions, explain any limitations and clearly mention what***

cannot be confirmed from the available information. Use simple language and do not make unsupported claims."

D3. Corrected Security Advice

The scholarship email should be treated as suspicious until it is verified through official college sources. Students should not click unknown links or share their passwords, OTPs or identity documents through unverified messages. HTTPS only provides an encrypted connection and does not guarantee that a website is genuine. The sign-in logs show unusual login activity from a different IP address, but they do not prove who accessed the account or how the password was obtained. MFA provides additional security but cannot prevent every account attack, especially when unexpected requests are approved. If unauthorised access is suspected, the IT team should secure the account, reset compromised credentials, preserve the login records and investigate the activity. All findings should be checked before drawing conclusions.

D4. AI-Use Declaration and Evidence/Reference Notes

AI-Use Declaration:

AI Tool Used: ChatGPT , Gemini

Purpose: AI assistance was used to understand cybersecurity concepts, organise the answers and improve the clarity of explanations. The assessment evidence and final answers were reviewed to ensure that the information was relevant and accurate.

Evidence and Reference Notes:

1. **CISA – Secure Our World:** This reference provides guidance on using strong passwords, enabling multi-factor authentication, recognising phishing messages and keeping software updated

Website: https://www.cisa.gov/secure-our-world

2. **NIST – Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (AI 600-1):** This reference explains risks associated with generative AI, including incorrect or unsupported AI-generated information. It supports the need to verify AI answers instead of accepting them without checking.

PDF: https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf